

AWS Linux Security & Compliance Assessment Lab

A simulated AWS and Linux security assessment project demonstrating cloud-security review, audit evidence collection, risk identification, and remediation planning.

Project Summary

This project documents a hands-on assessment of a simulated AWS environment with a Linux workload. The objective was to review identity and access controls, logging and monitoring coverage, Linux security posture, and cloud configuration risks; collect audit-oriented evidence; and produce remediation recommendations aligned with common security and compliance practices.

The lab is intended to demonstrate practical skills relevant to cloud security, IT audit, governance, risk, compliance (GRC), and security assessment roles.

Objectives

- Configure and review AWS identity and access management controls.
- Enable and validate AWS activity logging and monitoring.
- Assess an AWS-hosted Linux system for basic security and hardening considerations.
- Run automated security checks with Prowler.
- Collect and organize evidence suitable for an audit or compliance review.
- Document findings, risks, recommended remediation, and validation steps.
- Relate assessment activity to NIST CSF and SOC 2-style control concepts.

Environment and Tools

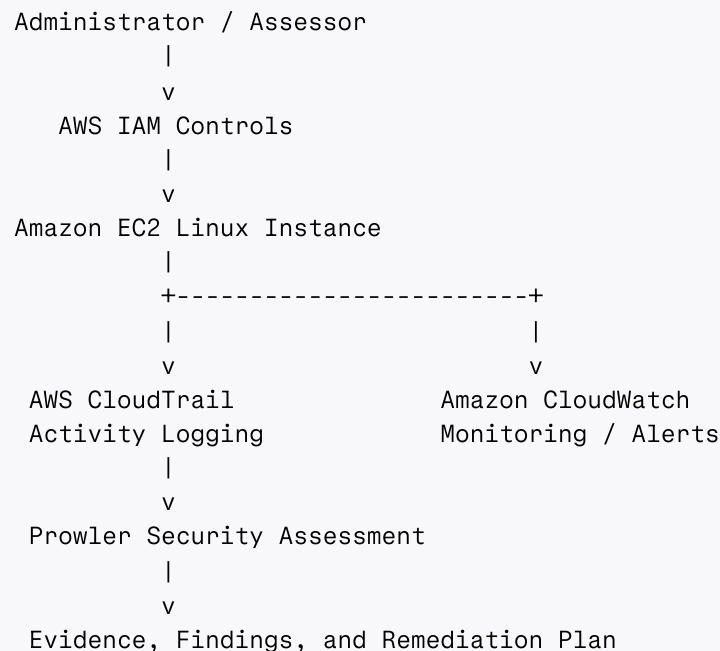
Area	Technologies / Concepts Used
Cloud platform	AWS
Identity and access	AWS IAM, users, groups, roles, least privilege
Compute	Amazon EC2, Linux
Logging	AWS CloudTrail
Monitoring	Amazon CloudWatch
Security assessment	Prowler
Host assessment	Linux CLI and Bash
Security frameworks	NIST Cybersecurity Framework, SOC 2 concepts
Documentation	Risk register, evidence collection, remediation plan

Assessment Scope

The assessment focused on the following areas:

- IAM users, roles, policies, and least-privilege access.
- Multi-factor authentication and privileged-account controls.
- CloudTrail logging configuration and log visibility.
- CloudWatch monitoring and alerting coverage.
- Security findings generated by Prowler.
- Linux account, permission, service, patching, and logging checks.
- Documentation of evidence, risk ratings, and remediation recommendations.

Architecture Overview



Assessment Methodology

1. Defined the assessment scope and cloud resources to be reviewed.
2. Reviewed IAM configuration, privileged access, and policy permissions.
3. Verified logging and monitoring configuration using CloudTrail and CloudWatch.
4. Performed Linux-level checks for users, permissions, services, logs, and basic hardening settings.
5. Ran Prowler to identify potential AWS configuration risks.
6. Collected sanitized screenshots, command output, and assessment reports as evidence.
7. Recorded findings with risk severity, impact, recommendation, and verification status.
8. Mapped applicable activities to security and compliance control concepts.

Key Findings and Remediation

Replace the examples below with the actual findings from this lab. Do not include account IDs, access keys, IP addresses, hostnames, or other sensitive information.

ID	Example finding	Risk	Recommendation	Status
F-01	IAM permissions were broader than required for the assigned task.	High	Apply least-privilege policies, remove unused permissions, and use roles where appropriate.	Documented / Remediated
F-02	CloudTrail logging coverage or retention required review.	Medium	Enable multi-region logging, centralize logs, restrict access, and establish a retention standard.	Documented / Remediated
F-03	CloudWatch alarms did not cover all high-value security events.	Medium	Configure alerts for IAM changes, failed authentication activity, and CloudTrail configuration changes.	Documented / Remediated
F-04	Linux account, permission, or service configuration required hardening.	Medium	Remove unused accounts/services, review file permissions, apply updates, and centralize logs.	Documented / Remediated
F-05	Prowler identified configuration checks requiring review.	Varies	Validate each finding, prioritize by risk and applicability, then remediate or document an accepted exception.	Documented / In progress

Evidence Included

This repository contains sanitized evidence only. Suggested folders and artifacts include:

```
├─ README.md
├─ docs/
│   ├── assessment-scope.md
│   ├── findings-and-remediation.md
│   ├── risk-register.md
│   └─ project-report.pdf
├─ evidence/
│   ├── iam-review.png
│   ├── cloudtrail-enabled.png
│   ├── cloudwatch-monitoring.png
│   ├── prowler-summary-sanitized.png
│   └─ linux-command-output-sanitized.txt
├─ scripts/
│   ├── linux-security-checks.sh
│   └─ evidence-collection-commands.md
└─ .gitignore
```

Sample Linux Evidence Commands

The following commands are examples of checks that can be documented as evidence. Review commands before running them and sanitize outputs before uploading them.

```
# Identify the current user and group membership
whoami
id

# Review local user accounts
cut -d: -f1 /etc/passwd

# Review currently running services
systemctl list-units --type=service --state=running

# Review listening network ports
ss -tulpn

# Review recent authentication activity
sudo journalctl -u ssh --since "7 days ago"

# Review package updates (command varies by Linux distribution)
sudo apt update && apt list --upgradable
# or
sudo dnf check-update

# Review permissions on sensitive directories
ls -ld /etc /var/log /home
```

Control Alignment

Assessment activity	Example alignment
IAM least-privilege review	NIST CSF Protect; SOC 2 logical access concepts
CloudTrail configuration review	NIST CSF Detect; audit logging and monitoring concepts
CloudWatch alert review	NIST CSF Detect / Respond; security event monitoring concepts
Linux account and service review	NIST CSF Protect; secure configuration concepts
Prowler findings review	Continuous monitoring, vulnerability/configuration management concepts
Evidence preservation	Auditability, security monitoring, and compliance evidence concepts

Skills Demonstrated

- AWS IAM access review and least-privilege analysis.
- AWS CloudTrail and CloudWatch configuration validation.
- Linux command-line security assessment and evidence collection.
- Prowler-based cloud security configuration assessment.
- Risk identification, severity rating, and remediation planning.
- NIST and SOC 2-oriented control mapping.
- Audit-ready technical documentation and evidence handling.

Security and Privacy Notice

This repository represents a simulated learning environment. It does not contain real organizational data, credentials, private keys, AWS access keys, account identifiers, live IP addresses, sensitive logs, or confidential infrastructure details.

Before publishing, verify that all screenshots, reports, command outputs, and configuration files have been sanitized.

Author

Lucansy Tuffour

Cybersecurity Governance, Risk, Compliance, and IT Audit Portfolio Project